FICTIONAL PROTOTYPE · Fictional organisation · Test-fixture figures, not an approved score · Not a certified paid report

MK FRAUD INSIGHTS

COMPREHENSIVE FRAUD READINESS REPORT

Fraud scenarios, target controls and implementation programme

On its own answers, the organisation reports the controls in place for 37 of the 49 fraud scenarios that apply and a control reported as a gap in 10.

CALCULATED TEST RESULT

78.5 of 100, test fixture

UNRESOLVED INCONSISTENCIES

None found

PROVISIONAL MANAGEMENT INTERPRETATION

10 with a control reported as a gap

APPROVED READINESS CONCLUSION

None issued

PREPARED FOR

Fictional Owner-Managed Firm

Assessment reference · FX-P4

CONFIDENTIAL · AUTOMATED ANALYSIS · NOT INDEPENDENTLY REVIEWED

HOW TO READ THIS REPORT

Contents

Management report	SECTIONS 1–9
1 · Where the organisation stands	
2 · What is driving the position	
3 · Reported fraud scenarios	
4 · How the scenarios could occur	
5 · The control environment management should build	
6 · Who must own the response	
7 · Decisions leadership must make	
8 · Proposed implementation stages	
9 · How management will know it is working	

Registers	APPENDICES A–J
A · Finding register	11 entries
B · Fraud risk register	10 entries
C · Control blueprint register	15 entries
D · Records management should maintain	15 entries
E · Action register	16 entries
F · Management scorecard	15 entries
G · Answer relationships	1 entries
H · Outstanding information	0 entries
I · Roles used in this report	5 entries
J · Information coverage	6 entries

THE TWO HALVES OF THIS REPORT

Sections 1–9 are the management report. The appendices hold every scenario, risk, control blueprint, record, action, measure, answer relationship and outstanding answer behind it, and the supporting workbook holds the same registers with the method references that trace each row to the question asked and the answer given.

BASIS OF THIS REPORT

TEST FIXTURE: hypothetical research value (scoring-frame simulation, Option A, midpoint, equal areas, no caps). Not an approved score, band or rating. This report is produced by fixed rules from the organisation's answers to the MK Fraud Readiness review, read against the draft review method and the draft control-content library, neither of which MK has yet approved. The AI manuscript stage has not been run; the interpretation in each section is fixed-rule text. No evidence has been examined, no control has been tested for operating effectiveness, no one has been interviewed and no assurance opinion is given. Records named in this report are records management should maintain; independent review of evidence is a separate Advisory service.

SECTION 1 · WHERE THE ORGANISATION STANDS

What the assessment establishes

Four separate statements, made the same way for every organisation: what was calculated, what is inconsistent, how the answers read, and what has been concluded. Nothing here has been tested or verified.

CALCULATED TEST RESULT

78.5 of 100, test fixture

From a research simulation of the draft method, kept for traceability. It is not a score, a maturity band or a readiness level.

PROVISIONAL MANAGEMENT INTERPRETATION

10 with a control reported as a gap

On its own answers, the organisation reports the controls that stop the scenario in place for 37 of the 49 fraud scenarios that apply, and a control reported as a gap in 10. This reads self-reported answers; nothing has been tested.

UNRESOLVED INCONSISTENCIES

None found

None found in the 1 pair of answers compared. Most related practices were not asked, so this is not a finding that every answer is consistent.

APPROVED READINESS CONCLUSION

None issued

MK has not approved a readiness method, band or threshold, so no readiness conclusion is drawn from the answers or from the calculated test result.

AREA	SCENARIOS	IN PLACE	IN PLACE, RELATED PRACTICE WEAKER	GAP	TO SETTLE	TO CLARIFY	NOT ANALYSED	CALCULATED TEST RESULT*
Fraud governance and accountability	11	11	0	0	0	0	0	90.0
Fraud risk assessment	6	6	0	0	0	0	0	91.7
Ethics, integrity and anti-corruption	6	5	1	0	0	0	0	86.7
Finance, banking and financial reporting	6	6	0	0	0	0	0	100.0
Assets, cash and inventory	1	0	0	0	0	0	1	Not calculated
Digital, cyber-enabled and identity fraud	11	0	0	10	0	0	1	16.0
Detection, speak-up and response	8	8	0	0	0	0	0	86.7

* TEST FIXTURE: hypothetical research value (scoring-frame simulation, Option A, midpoint, equal areas, no caps). Not an approved score, band or rating. Shown for traceability only: not a score, a band or a ranking of the areas.

WHAT THIS MEANS

The organisation answered 49 of the 49 confirmations that apply, 23 of 23 in the core stage. Of the diagnostic questions put to it, 22 of 22 were answered; the rest of the method's diagnostic questions were not asked, and nothing is concluded about them (Appendix J). The tier of a scenario says how early the method asks about it, not how serious it is, and the calculated test result is not a readiness level.

SECTION 2 · WHAT IS DRIVING THE POSITION

The patterns behind the answers

Answers to settle and questions to clarify first, because a control relied on as reported may not operate that way; then requirements that span areas, and the count of gaps by area.

Scenarios with a control reported as a gap, by area

AREA	SCENARIOS WITH A GAP	SCENARIOS IN THE AREA
Digital, cyber-enabled and identity fraud	10	11

Areas in the method's order. A count of scenarios is not a measure of their seriousness.

WHAT THIS MEANS

No answers conflict in the pairs compared, and no reviewed pair leaves a question open. 10 scenarios have a control reported as a gap, across 1 area.

SECTION 3 · REPORTED FRAUD SCENARIOS

The scenarios this report acts on, by area

Every scenario with answers to settle, a question to clarify or a control reported as a gap, in the method's order. MK has not approved a method for rating fraud risks, so no likelihood, impact, materiality or priority is assigned, and neither the order nor the tier is a ranking. Each scenario's finding is in Appendix A and its risk statement in Appendix B.

AREA	ACTED ON	SCENARIOS
Digital, cyber-enabled and identity fraud	10	An email account is taken over S31; A payment instruction received by email is acted on S32; A cloned voice or video instruction is obeyed S33; A security compromise is not notified S34; A help desk reset hands an attacker access S35; Systems that move money are accessed without strong sign-in S36; Personal information is over-exposed or kept too long S37; The organisation's own information helps attackers S38; A compromise is not contained quickly S39; Spoofed email in the organisation's name deceives staff, suppliers or customers S41

A further 1 scenario has the control that stops it reported in place with a related practice weaker. They are in Appendix A, and the related practices in Appendix C.

WHAT THIS MEANS

10 scenarios are acted on across 1 area. The grouping shows where the work sits; Section 7 asks management to decide the order, using explicit factors.

SECTION 4 · HOW THE SCENARIOS COULD OCCUR

Illustrative exposure mechanisms

Included: every scenario with answers to settle or a question to clarify (up to three), then the first scenario with a control reported as a gap in each area, in the method's order, up to six in all. They are plausible pathways for an organisation with the controls it reported, not allegations that any event has occurred, and their inclusion is not a ranking.

An email account is taken over

S31 · DIGITAL CHANNELS

HOW IT STARTS	A mailbox without strong sign-in is used to send or intercept payment instructions.
WHY IT MATTERS	Most business email compromise starts with an account that has no multi-factor authentication.
WHAT THE ANSWERS SHOW	Multi-factor on all email: email accounts are protected by passwords only.
WHAT WOULD INTERRUPT IT	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.
WARNING SIGNS	Takeover of staff accounts; Business email compromise and payment redirection
LINKS	F02, FR01, C02

9 further scenarios are described in Appendices A and B.

SECTION 5 · THE CONTROL ENVIRONMENT MANAGEMENT SHOULD BUILD

Target controls, by accountable role

One programme for each accountable role, in alphabetical order. Each control's blueprint, with its target practice, activities, records and success measure, is in Appendix C; here it is named with its reference.

Chief financial officer

5 CONTROLS

SCENARIOS	a payment instruction received by email is acted on and a cloned voice or video instruction is obeyed.
PUT IN PLACE	Email never enough on its own (C03); Verification for calls, voice notes and video (C04).
STRENGTHEN	Pressure triggers verification (C05); Gift cards and PIN requests banned (C06); Changes to call-back details verified (C07).

Commercial and customer lead

1 CONTROL

SCENARIOS	the organisation's own information helps attackers.
PUT IN PLACE	Staff guided on what not to share (C13).

HR and payroll lead

1 CONTROL

STRENGTHEN	Training on joining (C01).

IT lead

6 CONTROLS

SCENARIOS	an email account is taken over, a security compromise is not notified, a help desk reset hands an attacker access, systems that move money are accessed without strong sign-in, a compromise is not contained quickly and spoofed email in the organisation's name deceives staff, suppliers or customers.
PUT IN PLACE	Multi-factor on all email (C02); Compromises reported as POPIA requires (C08); Help desk resets verified (C10); Multi-factor on critical systems (C11); Compromise playbook (C14); Domain protected against spoofing (C15).

Legal and compliance lead

2 CONTROLS

SCENARIOS	personal information is over-exposed or kept too long.
PUT IN PLACE	Access to personal information limited (C12).
STRENGTHEN	Affected people warned (C09).

> **WHAT THIS MEANS**
>
> 10 controls are to be put in place and 5 are related practices to strengthen. No reviewed relationship establishes that one of these controls consumes another's output, so no control is sequenced before another for that reason. Each blueprint comes from MK's draft control-content library (control-content-library-0.1), which MK has not yet approved.

SECTION 6 · WHO MUST OWN THE RESPONSE

Accountability by role

Roles, not individuals: the assessment does not identify people. The method suggests owners in many forms; this report uses one label per function, and Appendix I lists the method's wording behind each. Oversight: the owners, from the organisation's own answer.

ROLE	CONTROLS	SCENARIOS	ACTIONS	ANSWERS TO SETTLE OR QUESTIONS TO ANSWER
Chief executive	0	10	4	Names the accountable executives, decides the order of work and reports status to the owners.
Chief financial officer	5	2	3	None
Commercial and customer lead	1	1	2	None
HR and payroll lead	1	1	2	None
IT lead	6	6	2	None
Legal and compliance lead	2	2	3	None

SECTION 7 · DECISIONS LEADERSHIP MUST MAKE

The decision agenda

A recommended direction follows the method and the answers; the decision remains management's. No deadline is set: "when" states what each decision must come before.

REF	DECISION	WHY	RECOMMENDED DIRECTION	WHEN	IF DELAYED
D01	**Name one accountable executive for each area with open or unresolved scenarios: digital channels (10).**	Each scenario needs one person with authority over the process, the system and the people involved.	The method suggests: IT lead for digital channels.	Before design work starts.	Open scenarios have no owner, and the controls that stop them stay unassigned.
D02	**Decide the order in which the open scenarios are addressed, using explicit factors.**	MK has not approved a method for rating fraud risks, so this report does not rank them, and neither its order nor the method's tiers is a ranking.	Settle conflicting answers and open questions first. Then weigh, for each scenario, how far its control is reported in place, whether money, pay, cash or stock can leave without it, how much activity passes through the process, whether another control would detect a loss, and how many other scenarios the same control serves. The finding register gives the facts the assessment holds for the first and last of these; management supplies the rest.	Before design work starts.	Effort is spread across every scenario at once, or follows the order of this report, which is not a ranking.
D03	**Have the owners receive the status of the open and unresolved scenarios at each of its meetings until each is closed, deferred with a reason or accepted.**	Regular reporting keeps the scenarios visible to the people who can remove blockers.	A one-page status per scenario: owner, controls in place, controls outstanding, next step.	From the first meeting after this report.	Progress is not visible until the next assessment.

SECTION 8 · PROPOSED IMPLEMENTATION STAGES

A twelve-month programme, in proposed stages

Each stage has a proposed planning window for when it could start. The windows are proposals for management's own plan: not deadlines, not contractual dates and not estimates of how long any control takes to design, put in place or show to be operating. Every action is in Appendix E.

STAGE	STAGE	PROPOSED WINDOW	PURPOSE	ACTIONS	INCLUDES
1	**Decide and assign**	Proposed start: months 1 to 3	Name who is accountable for each area, decide the order of work using explicit factors, and approve the target designs.	3	Name the executive accountable for digital channels, where 10 scenarios are open or unresolved. Decide which of the 10 scenarios with a control reported as a gap to address in this cycle, and in what order, using the decision factors in the finding register. 1 more in Appendix E.
2	**Put the selected controls in place**	Proposed start: once designs are approved	The controls reported as gaps for the scenarios management has selected.	4	Put in place the 6 controls the IT lead owns: multi-factor on all email (C02), compromises reported as POPIA requires (C08), help desk resets verified (C10), multi-factor on critical systems (C11), compromise playbook (C14) and domain protected against spoofing (C15). Put in place the 2 controls the chief financial officer owns: email never enough on its own (C03) and verification for calls, voice notes and video (C04). 2 more in Appendix E.
3	**Strengthen further defences**	Proposed start: after the first controls are in place	Related practices reported weaker behind a control reported in place or a gap.	3	Strengthen the control the HR and payroll lead owns: training on joining (C01). Strengthen the 3 controls the chief financial officer owns: pressure triggers verification (C05), gift cards and PIN requests banned (C06) and changes to call-back details verified (C07). 1 more in Appendix E.
4	**Operate, measure and report**	From the first control in operation, through month 12	Run each control through at least one full operating cycle, check it against its success measure and report status to the oversight body.	6	Check the control owned by the HR and payroll lead against its success measure once it has completed its first full operating cycle. Check each of the 6 controls owned by the IT lead against its success measure once it has completed its first full operating cycle. 4 more in Appendix E.

WHAT THIS MEANS

The first two stages need no new control: they establish the facts, name owners and decide the order of work. No control here consumes another's output as far as reviewed relationships establish, so no prerequisite stage is needed. A control counts as working only after it has met its success measure for at least one full operating cycle; for annual controls that may fall beyond the twelve months. Status is reported to the owners throughout.

SECTION 9 · HOW MANAGEMENT WILL KNOW IT IS WORKING

Indicators and the management scorecard

Each control has one success measure, stated as the outcome its records should show for a period (Appendix F). They are the signals management should expect once a control operates, not a claim that they exist today.

INDICATOR	TODAY	EXPECTED
Open scenarios with a named owner and a recorded decision	None recorded (10 open)	Every open scenario selected, deferred with a reason or accepted
Controls meeting their success measure for a full cycle	Not measured	Each control put in place (10), then each related practice strengthened
Status reported to the owners	Not yet	At each meeting until each scenario is closed, deferred or accepted

The scorecard, by owner

OWNER	MEASURES	MOST COMMON OPERATING CYCLES
Chief financial officer	5	each year (4); whenever a change is requested (1)
Commercial and customer lead	1	each year (1)
HR and payroll lead	1	monthly (1)
IT lead	6	monthly (2); each year (2); whenever a reset is requested (1)
Legal and compliance lead	2	each year (1); each quarter (1)

CONCLUSION

On its own answers, Fictional Owner-Managed Firm reports the controls in place for 37 of 49 fraud scenarios and a control reported as a gap in 10. MK has not approved a readiness method, so the report draws no readiness conclusion and does not rank fraud risks; it sets out what each scenario needs, who owns it, the records to keep and how management will know each control is working.

APPENDIX A

Finding register

Every scenario with answers to settle, a question to clarify, a control reported as a gap or a related practice weaker, in the method's order. "What the answers show" is self-reported and has not been verified. Decision factors are the facts the assessment holds for ordering the work; they are not a rating.

REF	SCENARIO	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	DECISION FACTORS
F01 S23	**Staff do not know or understand what is expected** Ethics, integrity and anti-corruption CONTROL IN PLACE; RELATED PRACTICE WEAKER	Code accessible to staff: reported in place across everything it should cover. Related practices reported weaker: training on joining (partly in place). Answered by HR and payroll and the respondent.	Expectations are not communicated in a way people understand, and nobody checks.	In place; related practice weaker C01
F02 S31	**An email account is taken over** Digital, cyber-enabled and identity fraud CONTROL REPORTED AS A GAP	Multi-factor on all email: email accounts are protected by passwords only. Answered by the respondent.	A mailbox without strong sign-in is used to send or intercept payment instructions. Most business email compromise starts with an account that has no multi-factor authentication.	Not in place FR01, C02
F03 S32	**A payment instruction received by email is acted on** Digital, cyber-enabled and identity fraud CONTROL REPORTED AS A GAP	Email never enough on its own: payment changes received by email are acted on as received. Answered by the respondent.	Changed details or urgent payments are processed on the strength of an email. Acting on payment instructions received by email is how business email compromise succeeds.	Not in place FR02, C03
F04 S33	**A cloned voice or video instruction is obeyed** Digital, cyber-enabled and identity fraud CONTROL REPORTED AS A GAP	Verification for calls, voice notes and video: some staff check unusual requests, depending on their own judgement. Related practices also reported weaker: pressure triggers verification (partly in place), changes to call-back details verified (partly in place) and gift cards and PIN requests banned (partly in place). Answered by the respondent and Finance.	A caller who sounds or looks like a known person is believed. Voices and faces can be cloned, so only an agreed verification method holds.	Partly in place FR03, C04, C05, C07, C06
F05 S34	**A security compromise is not notified** Digital, cyber-enabled and identity fraud CONTROL REPORTED AS A GAP	Compromises reported as POPIA requires: a compromise would be handled as it happens, without a set process. Related practices also reported weaker: affected people warned (not in place). Answered by IT and information and the respondent.	The Regulator and affected people are not told, so they cannot protect themselves. POPIA section 22 requires notification as soon as reasonably possible.	Partly in place FR04, C08, C09
F06 S35	**A help desk reset hands an attacker access** Digital, cyber-enabled and identity fraud CONTROL REPORTED AS A GAP	Help desk resets verified: most resets need verification through a trusted route, such as the person's manager or a number on file. Answered by the respondent.	An impersonator persuades the help desk to reset a password or authenticator.	Partly in place FR05, C10
F07 S36	**Systems that move money are accessed without strong sign-in** Digital, cyber-enabled and identity fraud CONTROL REPORTED AS A GAP	Multi-factor on critical systems: these systems are protected by passwords only. Answered by the respondent.	Remote access, cloud or banking systems rely on passwords alone.	Not in place FR06, C11
F08 S37	**Personal information is over-exposed or kept too long** Digital, cyber-enabled and identity fraud CONTROL REPORTED AS A GAP	Access to personal information limited: access is limited for some systems only. Answered by the respondent.	Too many people can reach or export personal information, or records outlive their purpose.	Partly in place FR07, C12
F09 S38	**The organisation's own information helps attackers** Digital, cyber-enabled and identity fraud CONTROL REPORTED AS A GAP	Staff guided on what not to share: reported as not in place. Answered by the respondent.	Published staff details and routines make impersonation easier.	Not in place FR08, C13
F10 S39	**A compromise is not contained quickly** Digital, cyber-enabled and identity fraud CONTROL REPORTED AS A GAP	Compromise playbook: there is no plan; each case would be handled from scratch. Answered by the respondent.	Accounts stay compromised while suppliers and customers keep receiving instructions.	Not in place FR09, C14

REF	SCENARIO	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	DECISION FACTORS
F11 S41	**Spoofed email in the organisation's name deceives staff, suppliers or customers** Digital, cyber-enabled and identity fraud CONTROL REPORTED AS A GAP	Domain protected against spoofing: partly in place. Answered by the respondent.	Emails that appear to come from the organisation's own domain carry false payment instructions.	Partly in place FR10, C15

APPENDIX B

Fraud risk register

One risk for each scenario with a control reported as a gap or answers to settle. No likelihood, impact, priority or monetary value is assigned: MK has not yet approved a method for rating them.

REF	RISK	CURRENT POSITION	TREATMENT	OWNER
FR01 F02	**A mailbox without strong sign-in is used to send or intercept payment instructions, because multi-factor on all email is not in place.** Most business email compromise starts with an account that has no multi-factor authentication. Not rated.	Email accounts are protected by passwords only.	C02 Multi-factor on all email	IT lead
FR02 F03	**Changed details or urgent payments are processed on the strength of an email, because email never enough on its own is not in place.** Acting on payment instructions received by email is how business email compromise succeeds. Not rated.	Payment changes received by email are acted on as received.	C03 Email never enough on its own	Chief financial officer
FR03 F04	**A caller who sounds or looks like a known person is believed, because verification for calls, voice notes and video is partly in place.** Voices and faces can be cloned, so only an agreed verification method holds. Not rated.	Some staff check unusual requests, depending on their own judgement.	C04 Verification for calls, voice notes and video; C05 Pressure triggers verification; C07 Changes to call-back details verified; C06 Gift cards and PIN requests banned	Chief financial officer
FR04 F05	**The Regulator and affected people are not told, so they cannot protect themselves, because compromises reported as POPIA requires is partly in place.** POPIA section 22 requires notification as soon as reasonably possible. Not rated.	A compromise would be handled as it happens, without a set process.	C08 Compromises reported as POPIA requires; C09 Affected people warned	IT lead
FR05 F06	**An impersonator persuades the help desk to reset a password or authenticator, because help desk resets verified is partly in place.** Not rated.	Most resets need verification through a trusted route, such as the person's manager or a number on file.	C10 Help desk resets verified	IT lead
FR06 F07	**Remote access, cloud or banking systems rely on passwords alone, because multi-factor on critical systems is not in place.** Not rated.	These systems are protected by passwords only.	C11 Multi-factor on critical systems	IT lead
FR07 F08	**Too many people can reach or export personal information, or records outlive their purpose, because access to personal information limited is partly in place.** Not rated.	Access is limited for some systems only.	C12 Access to personal information limited	Legal and compliance lead
FR08 F09	**Published staff details and routines make impersonation easier, because staff guided on what not to share is not in place.** Not rated.	Staff guided on what not to share: reported as not in place.	C13 Staff guided on what not to share	Commercial and customer lead
FR09 F10	**Accounts stay compromised while suppliers and customers keep receiving instructions, because compromise playbook is not in place.** Not rated.	There is no plan; each case would be handled from scratch.	C14 Compromise playbook	IT lead
FR10 F11	**Emails that appear to come from the organisation's own domain carry false payment instructions, because domain protected against spoofing is partly in place.** Not rated.	Domain protected against spoofing: partly in place.	C15 Domain protected against spoofing	IT lead

APPENDIX C

Control blueprint register

Each control once, with every scenario it serves, grouped by what is to be done and then in the method's order. "Reported today" is what the organisation answered; the target practice, activities, records, measure and failure response come from MK's draft control-content library (control-content-library-0.1), which is advisory content and not approved. The method's own wording and source references for each control are in the supporting workbook.

PUT IN PLACE · 10

C02 Multi-factor on all email

IT LEAD · S31

REPORTED TODAY
Email accounts are protected by passwords only.

TARGET OPERATING PRACTICE
Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.

IMPLEMENTATION ACTIVITIES
1. List every email account in scope and how it is set today.
2. Apply the setting to each, starting with executives' and finance mailboxes, and record any approved exception.
3. Produce the email security report monthly, and follow up any gap.

RECORDS TO KEEP · E02
Email security report
Cycle: monthly

SUCCESS MEASURE · M02
At the end of the period, the email security report shows multi-factor authentication on every email account, including executives' and shared mailboxes, and any exception is approved and recorded.

IF IT FAILS
Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

C03 Email never enough on its own

CHIEF FINANCIAL OFFICER · S32

REPORTED TODAY
Payment changes received by email are acted on as received.

TARGET OPERATING PRACTICE
An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.

IMPLEMENTATION ACTIVITIES
1. Write the rule and have it approved by the chief executive.
2. Brief staff who act on payment or salary requests, including executives and their assistants, and record who has been briefed.
3. Test the rule at least once a year, for example with a simulated request, and act on the result.

RECORDS TO KEEP · E03
Verification rule record
Cycle: each year

SUCCESS MEASURE · M03
All staff who act on payment or salary requests were briefed by the end of the period, and the most recent test found the rule followed in every case tested.

IF IT FAILS
Where the rule was not followed, establish why, brief the people concerned again and check whether any payment or disclosure resulted.

C04 Verification for calls, voice notes and video

CHIEF FINANCIAL OFFICER · S33

REPORTED TODAY
Some staff check unusual requests, depending on their own judgement.

TARGET OPERATING PRACTICE
An agreed method, such as a call-back on a known number or a code word, verifies any request made by phone, voice note or video; it applies to everyone, including executives, and staff know they are expected to use it.

IMPLEMENTATION ACTIVITIES
1. Write the rule and have it approved by the chief executive.
2. Brief staff who act on requests by phone, voice note or video, including executives and their assistants, and record who has been briefed.
3. Test the rule at least once a year, for example with a simulated request, and act on the result.

RECORDS TO KEEP · E04
Verification method record
Cycle: each year

SUCCESS MEASURE · M04
All staff who act on requests by phone, voice note or video were briefed by the end of the period, and the most recent test found the rule followed in every case tested, including requests that appeared to come from executives.

IF IT FAILS
Where the rule was not followed, establish why, brief the people concerned again and check whether any payment or disclosure resulted.

C08 **Compromises reported as POPIA requires**

IT LEAD · S34

REPORTED TODAY

A compromise would be handled as it happens, without a set process.

TARGET OPERATING PRACTICE

A procedure sets out who decides, who notifies the Information Regulator through its eServices portal and the people affected, and how quickly, as section 22 of POPIA requires.

IMPLEMENTATION ACTIVITIES

1. Write the procedure, naming who decides and who acts at each step.
2. Brief the people with a role in it, and keep the contact details it relies on current.
3. Test it each year with an exercise or a real case, and record what changed as a result.

RECORDS TO KEEP · E08

Breach response procedure
Cycle: each year

SUCCESS MEASURE · M08

In the period, the procedure was tested or used, and every compromise discovered was notified as soon as reasonably possible, with any delay justified and recorded.

IF IT FAILS

Where the procedure was not followed or did not work, record why, correct it and brief the people concerned.

C10 **Help desk resets verified**

IT LEAD · S35

REPORTED TODAY

Most resets need verification through a trusted route, such as the person's manager or a number on file.

TARGET OPERATING PRACTICE

Every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.

IMPLEMENTATION ACTIVITIES

1. Write the confirmation step into the procedure: a call-back to a number on file, or a manager's confirmation through a known channel, never details supplied with the request.
2. Limit who can make the change in the help desk system, and log how each change was confirmed.
3. Check the password and multi-factor resets made in the last six months against the log, and confirm any that were not verified.

RECORDS TO KEEP · E10

Reset log
Cycle: whenever a reset is requested

SUCCESS MEASURE · M10

Every password or multi-factor reset made in the period was confirmed through a route the caller did not control before it took effect, or is a recorded and approved exception.

IF IT FAILS

Suspend any password or multi-factor reset that was not confirmed until it is verified, and check whether any payment, delivery or access used it.

C11 **Multi-factor on critical systems**

IT LEAD · S36

REPORTED TODAY

These systems are protected by passwords only.

TARGET OPERATING PRACTICE

Multi-factor authentication is required for remote access, cloud systems, the banking platform and every system that can move money or change master data.

IMPLEMENTATION ACTIVITIES

1. List every system or access route in scope and how it is set today.
2. Apply the setting to each, starting with the banking platform and remote access, and record any approved exception.
3. Produce the multi-factor coverage report monthly, and follow up any gap.

RECORDS TO KEEP · E11

Multi-factor coverage report
Cycle: monthly

SUCCESS MEASURE · M11

At the end of the period, the multi-factor coverage report shows multi-factor authentication on remote access, cloud systems, the banking platform and every system that can move money or change master data, and any exception is approved and recorded.

IF IT FAILS

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

C12 **Access to personal information limited**

LEGAL AND COMPLIANCE LEAD · S37

REPORTED TODAY

Access is limited for some systems only.

TARGET OPERATING PRACTICE

In every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged.

IMPLEMENTATION ACTIVITIES

1. List every system holding personal information in scope and how it is set today.
2. Apply the setting to each, starting with customer and employee systems, and record any approved exception.
3. Produce the access review each quarter, and follow up any gap.

RECORDS TO KEEP · E12

Access review
Cycle: each quarter

SUCCESS MEASURE · M12

At the end of the period, the access review shows access limited by role, and exports restricted and logged, in every system holding personal information, and any exception is approved and recorded.

IF IT FAILS

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

C13 **Staff guided on what not to share**

COMMERCIAL AND CUSTOMER LEAD · S38

REPORTED TODAY

Staff guided on what not to share: reported as not in place.

TARGET OPERATING PRACTICE

Staff are guided on what not to share about their work online, such as who approves payments or when executives are travelling, at induction and each year.

IMPLEMENTATION ACTIVITIES

1. Set the content and who must complete it, using current schemes relevant to their work.
2. Track completion each year, and follow up anyone who has not completed it.
3. Refresh the content each year, and test understanding where the risk is highest.

RECORDS TO KEEP · E13

Guidance record
Cycle: each year

SUCCESS MEASURE · M13

Every employee completed the training at induction and within the year, and completion is recorded.

IF IT FAILS

Follow up incomplete training with the person's manager, and restrict access to sensitive duties where the risk requires it.

C14 **Compromise playbook**

IT LEAD · S39

REPORTED TODAY

There is no plan; each case would be handled from scratch.

TARGET OPERATING PRACTICE

A written plan for an email compromise or account takeover covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles.

IMPLEMENTATION ACTIVITIES

1. Write the procedure, naming who decides and who acts at each step.
2. Brief the people with a role in it, and keep the contact details it relies on current.
3. Test it each year with an exercise or a real case, and record what changed as a result.

RECORDS TO KEEP · E14

Compromise response plan
Cycle: each year

SUCCESS MEASURE · M14

In the period, the plan was tested or used, and the actions arising are complete or on schedule.

IF IT FAILS

Where the procedure was not followed or did not work, record why, correct it and brief the people concerned.

C15 **Domain protected against spoofing**

IT LEAD · S41

REPORTED TODAY

Domain protected against spoofing: partly in place.

TARGET OPERATING PRACTICE

The organisation's email domains are protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject.

IMPLEMENTATION ACTIVITIES

1. List every email domain in scope and how it is set today.
2. Apply the setting to each, starting with the main sending domain, and record any approved exception.
3. Produce the domain protection report each quarter, and follow up any gap.

RECORDS TO KEEP · E15

Domain protection report
Cycle: each quarter

SUCCESS MEASURE · M15

At the end of the period, the domain protection report shows SPF, DKIM and a DMARC policy of quarantine or reject on every domain, and any exception is approved and recorded.

IF IT FAILS

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

STRENGTHEN · 5

C01 **Training on joining**

HR AND PAYROLL LEAD · S23

REPORTED TODAY

Training on joining: reported in place only in some areas, cases or periods. (answered by HR and payroll)

TARGET OPERATING PRACTICE

Every new employee completes fraud and ethics training in their first month, covering the code of conduct, how to report concerns and the schemes relevant to their role.

IMPLEMENTATION ACTIVITIES

1. Set the content and who must complete it, using current schemes relevant to their work.
2. Track completion monthly, and follow up anyone who has not completed it.
3. Refresh the content each year, and test understanding where the risk is highest.

RECORDS TO KEEP · E01

Training completion record
Cycle: monthly

SUCCESS MEASURE · M01

Every new employee completed the training within their first month, and completion is recorded.

IF IT FAILS

Follow up incomplete training with the person's manager, and restrict access to sensitive duties where the risk requires it.

C05 **Pressure triggers verification**

CHIEF FINANCIAL OFFICER · S33

REPORTED TODAY

Pressure triggers verification: reported in place only in some areas, cases or periods. (answered by Finance)

TARGET OPERATING PRACTICE

Requests for secrecy, urgency or skipping normal steps are treated as warning signs that require verification through a known channel, whoever appears to be asking.

IMPLEMENTATION ACTIVITIES

1. Write the rule and have it approved by the chief executive.
2. Brief staff who handle payments and sensitive requests, including executives and their assistants, and record who has been briefed.
3. Test the rule at least once a year, for example with a simulated request, and act on the result.

RECORDS TO KEEP · E05

Verification rule record
Cycle: each year

SUCCESS MEASURE · M05

All staff who handle payments and sensitive requests were briefed by the end of the period, and the most recent test found the rule followed in every case tested.

IF IT FAILS

Where the rule was not followed, establish why, brief the people concerned again and check whether any payment or disclosure resulted.

C06 **Gift cards and PIN requests banned**

CHIEF FINANCIAL OFFICER · S33

REPORTED TODAY

Gift cards and PIN requests banned: reported in place only in some areas, cases or periods. (answered by Finance)

TARGET OPERATING PRACTICE

Requests to buy gift cards, vouchers or airtime, or to share a one-time PIN, are refused outright, whoever seems to be asking.

IMPLEMENTATION ACTIVITIES

1. Write the rule and have it approved by the chief executive.
2. Brief staff, including executives and their assistants, and record who has been briefed.
3. Test the rule at least once a year, for example with a simulated request, and act on the result.

RECORDS TO KEEP · E06

Rule record
Cycle: each year

SUCCESS MEASURE · M06

All staff were briefed by the end of the period, and the most recent test found the rule followed in every case tested.

IF IT FAILS

Where the rule was not followed, establish why, brief the people concerned again and check whether any payment or disclosure resulted.

C07 **Changes to call-back details verified**

CHIEF FINANCIAL OFFICER · S33

REPORTED TODAY

Most changes are verified through the old details or another trusted route. (answered by Finance)

TARGET OPERATING PRACTICE

Every change to a phone number or email address used for verification is confirmed through the previous details or another trusted route before it is used.

IMPLEMENTATION ACTIVITIES

1. Write the confirmation step into the procedure: the previous details or another trusted route, never details supplied with the request.
2. Limit who can make the change, and log how each change was confirmed.
3. Check the changes to call-back details made in the last six months against the log, and confirm any that were not verified.

RECORDS TO KEEP · E07

Contact change log
Cycle: whenever a change is requested

SUCCESS MEASURE · M07

Every change to call-back details made in the period was confirmed through the previous details or another trusted route before it took effect, or is a recorded and approved exception.

IF IT FAILS

Suspend any change to call-back details that was not confirmed until it is verified, and check whether any payment, delivery or access used it.

C09 **Affected people warned**

LEGAL AND COMPLIANCE LEAD · S34

REPORTED TODAY

Affected people warned: reported as not in place. (answered by IT and information)

TARGET OPERATING PRACTICE

When personal data is leaked, the people affected are warned about follow-up fraud, such as phishing that uses their real details, as part of the breach response.

IMPLEMENTATION ACTIVITIES

1. Write the procedure, naming who decides and who acts at each step.
2. Brief the people with a role in it, and keep the contact details it relies on current.
3. Test it each year with an exercise or a real case, and record what changed as a result.

RECORDS TO KEEP · E09

Breach response record
Cycle: each year

SUCCESS MEASURE · M09

In the period, everyone affected by a leak was warned about follow-up fraud.

IF IT FAILS

Where the procedure was not followed or did not work, record why, correct it and brief the people concerned.

APPENDIX D

Records management should maintain

The records each control should produce as it operates, for management to keep. MK has not requested, received or examined any of them. Independent review of evidence is a separate Advisory service; this report does not perform it.

REF	RECORD AND WHAT IT SHOWS	CONTROLS	KEPT BY
E01	Training completion record: each new employee, the training completed and the date.	C01	HR and payroll lead
E02	Email security report: the multi-factor status of every account, including shared mailboxes.	C02	IT lead
E03	Verification rule record: the rule, briefing records, call-back records and the results of each test.	C03	Chief financial officer
E04	Verification method record: the agreed method, briefing records and the results of each test.	C04	Chief financial officer
E05	Verification rule record: the rule, briefing records and the results of each test.	C05	Chief financial officer
E06	Rule record: the rule, briefing records and the results of each test.	C06	Chief financial officer
E07	Contact change log: each change to supplier or executive contact details, how it was confirmed and when.	C07	Chief financial officer
E08	Breach response procedure: the procedure, the notification templates, and each compromise with its notification dates and any justified delay.	C08	IT lead
E09	Breach response record: each leak, the people warned, the warning sent and the date.	C09	Legal and compliance lead
E10	Reset log: each reset, how the requester was verified, by whom and when.	C10	IT lead
E11	Multi-factor coverage report: each system and access route in scope, its multi-factor setting and any approved exception.	C11	IT lead
E12	Access review: each system, who has access and why, the export restrictions and the review date.	C12	Legal and compliance lead
E13	Guidance record: the guidance issued, to whom and when.	C13	Commercial and customer lead
E14	Compromise response plan: the plan, its contact list and the record of each test or incident.	C14	IT lead
E15	Domain protection report: each domain, its SPF, DKIM and DMARC settings and the date checked.	C15	IT lead

APPENDIX E

Action register

Every action in the programme, grouped by proposed stage. The windows are proposals for planning, not deadlines or estimates.

REF	ACTION	OWNER	DELIVERABLE	COMPLETE WHEN
STAGE 1 · DECIDE AND ASSIGN Proposed start: months 1 to 3				
A01	Name the executive accountable for digital channels, where 10 scenarios are open or unresolved.	Chief executive	A named accountable executive for the area.	The area has one named executive who has accepted the role.
A02	Decide which of the 10 scenarios with a control reported as a gap to address in this cycle, and in what order, using the decision factors in the finding register.	Chief executive	A recorded selection and order, with the factors that decided each choice.	Every open scenario is either selected, deferred with a reason, or accepted as a risk at the right level.
A03	Approve the target design for each selected control, using the target practice, records and measure in the control blueprint register.	Chief executive	Approved designs, each with an owner and the records it will keep.	Each selected control has an approved design and an owner.
STAGE 2 · PUT THE SELECTED CONTROLS IN PLACE Proposed start: once designs are approved				
A04	Put in place the 6 controls the IT lead owns: multi-factor on all email (C02), compromises reported as POPIA requires (C08), help desk resets verified (C10), multi-factor on critical systems (C11), compromise playbook (C14) and domain protected against spoofing (C15).	IT lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A05	Put in place the 2 controls the chief financial officer owns: email never enough on its own (C03) and verification for calls, voice notes and video (C04).	Chief financial officer	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A06	Put in place the control the legal and compliance lead owns: access to personal information limited (C12).	Legal and compliance lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A07	Put in place the control the commercial and customer lead owns: staff guided on what not to share (C13).	Commercial and customer lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
STAGE 3 · STRENGTHEN FURTHER DEFENCES Proposed start: after the first controls are in place				
A08	Strengthen the control the HR and payroll lead owns: training on joining (C01).	HR and payroll lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A09	Strengthen the 3 controls the chief financial officer owns: pressure triggers verification (C05), gift cards and PIN requests banned (C06) and changes to call-back details verified (C07).	Chief financial officer	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
A10	Strengthen the control the legal and compliance lead owns: affected people warned (C09).	Legal and compliance lead	Each control operating to its approved design, with the records named in its blueprint kept from the first case.	Each control has started operating, and its records exist for every case since it started.
STAGE 4 · OPERATE, MEASURE AND REPORT From the first control in operation, through month 12				
A11	Check the control owned by the HR and payroll lead against its success measure once it has completed its first full operating cycle.	HR and payroll lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A12	Check each of the 6 controls owned by the IT lead against its success measure once it has completed its first full operating cycle.	IT lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.

REF	ACTION	OWNER	DELIVERABLE	COMPLETE WHEN
A13	Check each of the 5 controls owned by the chief financial officer against its success measure once it has completed its first full operating cycle.	Chief financial officer	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A14	Check each of the 2 controls owned by the legal and compliance lead against its success measure once it has completed its first full operating cycle.	Legal and compliance lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A15	Check the control owned by the commercial and customer lead against its success measure once it has completed its first full operating cycle.	Commercial and customer lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A16	Report the status of every open and unresolved scenario to the owners at each of its meetings until each is closed, deferred with a reason or accepted.	Chief executive	A one-page status: scenario, owner, controls in place, controls outstanding, next step.	The status is received and minuted at each meeting.

APPENDIX F

Management scorecard

The success measures, grouped by the owner who reports them, with each control's operating cycle. Each measure is stated once, in full, in its control's blueprint (Appendix C) and in the supporting workbook.

MEASURE	CONTROL	CONTROL NAME	OPERATING CYCLE
CHIEF FINANCIAL OFFICER 5 measures			
M03	C03	Email never enough on its own	each year
M04	C04	Verification for calls, voice notes and video	each year
M05	C05	Pressure triggers verification	each year
M06	C06	Gift cards and PIN requests banned	each year
M07	C07	Changes to call-back details verified	whenever a change is requested
COMMERCIAL AND CUSTOMER LEAD 1 measure			
M13	C13	Staff guided on what not to share	each year
HR AND PAYROLL LEAD 1 measure			
M01	C01	Training on joining	monthly
IT LEAD 6 measures			
M02	C02	Multi-factor on all email	monthly
M08	C08	Compromises reported as POPIA requires	each year
M10	C10	Help desk resets verified	whenever a reset is requested
M11	C11	Multi-factor on critical systems	monthly
M14	C14	Compromise playbook	each year
M15	C15	Domain protected against spoofing	each quarter
LEGAL AND COMPLIANCE LEAD 2 measures			
M09	C09	Affected people warned	each year
M12	C12	Access to personal information limited	each quarter

APPENDIX G

Answer relationships

For each control reported fully in place, every related practice of the same scenario reported weaker, with no case yet or outstanding, and how the two relate. A practice answered "not applicable" is outside scope and is not listed. Only answers that cannot both be right, or a control lacking an input it needs, are unresolved inconsistencies; a reviewed pair the answers leave open is a question to clarify; a pair not yet reviewed supports no conclusion.

SCENARIO	CONTROL REPORTED IN PLACE	RELATED PRACTICE AND ITS ANSWER	RELATIONSHIP	WHAT IT MEANS
S23	**Code accessible to staff**	Training on joining: reported in place only in some areas, cases or periods.	FURTHER DEFENCE WEAKER; CONTROL STANDS Reviewed pair	Fraud and ethics training at joining is distinct from explaining conduct standards where employees work; induction is only one of the places Code accessible to staff names.

APPENDIX H

Outstanding information

Every question asked and not answered. A declined question, a question answered "I don't know" and a question still waiting are all outstanding; none is treated as answered.

No answer is outstanding.

APPENDIX I

Roles used in this report

Each consolidated role and the method's own suggested owners behind it.

ROLE IN THIS REPORT	METHOD WORDING
Chief financial officer	CFO and head of IT together
Commercial and customer lead	Communications or marketing manager
HR and payroll lead	HR or learning lead
IT lead	Head of IT or IT provider; Head of IT or information security
Legal and compliance lead	Information officer (POPIA)

APPENDIX J

Information coverage

What the assessment establishes and what remains unknown: the confirmations answered in each area and the diagnostic questions put to each function. Questions the method did not ask are not counted, and nothing is concluded about them.

AREA	CONFIRMATIONS THAT APPLY	ANSWERED	SHARE ANSWERED
Fraud governance and accountability	12	12	100%
Fraud risk assessment	6	6	100%
Ethics, integrity and anti-corruption	6	6	100%
Finance, banking and financial reporting	6	6	100%
Digital, cyber-enabled and identity fraud	10	10	100%
Detection, speak-up and response	9	9	100%

Diagnostic questions put to functions

FUNCTION	ASKED	ANSWERED	DECLINED	NOT KNOWN	WAITING
Risk and investigations	10	10	0	0	0
HR and payroll	3	3	0	0	0
IT and information	4	4	0	0	0
Finance	3	3	0	0	0
Legal, compliance and ethics	1	1	0	0	0